ZAP by Checkmarx Scanning Report

Generated with ZAP on Mon 23 Feb 2026, at 21:16:48

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=High, Confidence=Medium (4)
  - Risk=Medium, Confidence=High (1)
  - Risk=Medium, Confidence=Medium (3)
  - Risk=Medium, Confidence=Low (1)

- Risk=Low, Confidence=High (2)
- Risk=Low, Confidence=Medium (2)
- Risk=Informational, Confidence=High (1)
- Risk=Informational, Confidence=Medium (2)
- Risk=Informational, Confidence=Low (3)

- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `https://testphp.vulnweb.com`
- `http://testphp.vulnweb.com`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	4 (21.1%)	0 (0.0%)	4 (21.1%)
	Medium	0 (0.0%)	1 (5.3%)	3 (15.8%)	1 (5.3%)	5 (26.3%)
	Low	0 (0.0%)	2 (10.5%)	2 (10.5%)	0 (0.0%)	4 (21.1%)
	Informational	0 (0.0%)	1 (5.3%)	2 (10.5%)	3 (15.8%)	6 (31.6%)
	Total	0 (0.0%)	4 (21.1%)	11 (57.9%)	4 (21.1%)	19 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	https://testphp.vulnweb.com	0 (0)	1 (1)	0 (1)	0 (1)
	http://testphp.vulnweb.com	4 (4)	4 (8)	4 (12)	6 (18)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting (Reflected)	High	19 (100.0%)
SQL Injection	High	1 (5.3%)
SQL Injection - MySQL	High	9 (47.4%)
Total		19

Alert type	Risk	Count
SQL Injection - MySQL (Time Based)	High	5 (26.3%)
Absence of Anti-CSRF Tokens	Medium	5 (26.3%)
Content Security Policy (CSP) Header Not Set	Medium	5 (26.3%)
HTTP Only Site	Medium	1 (5.3%)
Missing Anti-clickjacking Header	Medium	5 (26.3%)
XSLT Injection	Medium	2 (10.5%)
In Page Banner Information Leak	Low	3 (15.8%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5 (26.3%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	5 (26.3%)
X-Content-Type-Options Header Missing	Low	5 (26.3%)
Authentication Request Identified	Informational	1 (5.3%)
Charset Mismatch (Header Versus Meta Content-Type Charset)	Informational	5 (26.3%)
GET for POST	Informational	3 (15.8%)
Total		19

Alert type	Risk	Count
Modern Web Application	Informational	5 (26.3%)
User Agent Fuzzer	Informational	5 (26.3%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	2 (10.5%)
Total		19

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	84
Low	Warning		ZAP warnings logged - see the zap.log file for details	27
Low	Exceeded High	http://testphp.vulnweb.com	Percentage of slow responses	100 %
Info	Informational	http://testphp.vulnweb.com	Percentage of responses with status code 2xx	81 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://testphp.vulnweb.com	Percentage of responses with status code 3xx	6 %
Info	Exceeded Low	http://testphp.vulnweb.com	Percentage of responses with status code 4xx	11 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with content type application/x-shockwave-flash	1 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with content type image/gif	3 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with content type image/jpeg	9 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with content type text/css	5 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with content type text/html	78 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with method GET	90 %
Info	Informational	http://testphp.vulnweb.com	Percentage of endpoints with method POST	9 %
Info	Informational	http://testphp.vulnweb.com	Count of total endpoints	51
Info	Informational	https://testphp.vulnweb.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://testphp.vulnweb.com	Count of total endpoints	1

Alerts

Risk=High, Confidence=Medium (4)

http://testphp.vulnweb.com (4)

Cross Site Scripting (Reflected) (1)

▶ POST http://testphp.vulnweb.com/secured/newuser.php

SQL Injection (1)

▶ POST http://testphp.vulnweb.com/guestbook.php

SQL Injection - MySQL (1)

▶ POST http://testphp.vulnweb.com/search.php?test=%27

SQL Injection - MySQL (Time Based) (1)

▶ POST http://testphp.vulnweb.com/secured/newuser.php

Risk=Medium, Confidence=High (1)

http://testphp.vulnweb.com (1)

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://testphp.vulnweb.com/robots.txt

Risk=Medium, Confidence=Medium (3)

https://testphp.vulnweb.com (1)

HTTP Only Site (1)

▶ GET http://testphp.vulnweb.com/hpp/?pp=12

http://testphp.vulnweb.com (2)

Missing Anti-clickjacking Header (1)

▶ GET http://testphp.vulnweb.com

XSLT Injection (1)

▶ GET http://testphp.vulnweb.com/showimage.php?file=%3Cxsl%3Avalue-of+select%3D%22document%28%27http%3A%2F%2Ftestphp.vulnweb.com%3A22%27%29%22%2F%3E

Risk=Medium, Confidence=Low (1)

http://testphp.vulnweb.com (1)

Absence of Anti-CSRF Tokens (1)

▶ GET http://testphp.vulnweb.com

Risk=Low, Confidence=High (2)

http://testphp.vulnweb.com (2)

In Page Banner Information Leak (1)

▶ GET http://testphp.vulnweb.com/robots.txt

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▶ GET http://testphp.vulnweb.com/robots.txt

Risk=Low, Confidence=Medium (2)

http://testphp.vulnweb.com (2)

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

▶ GET http://testphp.vulnweb.com

X-Content-Type-Options Header Missing (1)

▶ GET http://testphp.vulnweb.com

Risk=Informational, Confidence=High (1)

http://testphp.vulnweb.com (1)

GET for POST (1)

▶ GET http://testphp.vulnweb.com/guestbook.php

Risk=Informational, Confidence=Medium (2)

http://testphp.vulnweb.com (2)

Modern Web Application (1)

▶ GET http://testphp.vulnweb.com/AJAX/index.php

User Agent Fuzzer (1)

▶ POST http://testphp.vulnweb.com/guestbook.php

Risk=Informational, Confidence=Low (3)

http://testphp.vulnweb.com (3)

Authentication Request Identified (1)

▶ POST http://testphp.vulnweb.com/secured/newuser.php

Charset Mismatch (Header Versus Meta Content-Type Charset) (1)

▶ GET http://testphp.vulnweb.com

User Controllable HTML Element Attribute (Potential XSS) (1)

▶ POST http://testphp.vulnweb.com/search.php?test=query

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Cross Site Scripting (Reflected)

Source	raised by an active scanner (Cross Site Scripting (Reflected))
CWE ID	79
WASC ID	8
Reference	▪ https://owasp.org/www-community/attacks/xss/ ▪ https://cwe.mitre.org/data/definitions/79.html

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19

Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

SQL Injection - MySQL

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

SQL Injection - MySQL (Time Based)

Source	raised by an active scanner (SQL Injection - MySQL (Time Based))
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheet

s/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

- https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	- https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP - https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html - https://www.w3.org/TR/CSP/ - https://w3c.github.io/webappsec-csp/ - https://web.dev/articles/csp - https://caniuse.com/#feat=contentsecuritypolicy - https://content-security-policy.com/

HTTP Only Site

Source	raised by an active scanner (HTTP Only Site)
CWE ID	311

WASC ID	4
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html ▪ https://letsencrypt.org/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

XSLT Injection

Source	raised by an active scanner (XSLT Injection)
CWE ID	91
WASC ID	23
Reference	▪ https://book.hacktricks.wiki/en/pentesting-web/xslt-server-side-injection-extensible-stylesheet-language-transformations.html

In Page Banner Information Leak

Source	raised by a passive scanner (In Page Banner Information Leak)
CWE ID	497

WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens

- https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
- https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	• https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) • https://owasp.org/www-community/Security_Headers

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)
Reference	• https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Charset Mismatch (Header Versus Meta Content-Type Charset)

Source	raised by a passive scanner (Charset Mismatch)
CWE ID	436
WASC ID	15

Reference	▪ https://code.google.com/archive/p/browsersec/wikis/Part2.wiki#Character_set_handling_and_detection

GET for POST

Source	raised by an active scanner (GET for POST)
CWE ID	16
WASC ID	20

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg

User Controllable HTML Element Attribute (Potential XSS)

Source	raised by a passive scanner (User Controllable HTML Element Attribute (Potential XSS))
CWE ID	20
WASC ID	20
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html